



Корелација догађаја, ефективност контрола и учење

Безбедност као процес који се мери, проверава и унапређује

Проблем који решавамо

Завршна слика безбедности не састоји се од појединачних контрола, већ од њихове везе. Догађаји добијају смисао када се корелишу, контрола добија вредност када постоји свеж доказ да ради, а инцидент постаје прилика да се систем побољша без прикривања грешака.

ПРОБЛЕМ

Шта може поћи по злу

Завршна слика безбедности не састоји се од појединачних контрола, већ од њихове везе. Догађаји добијају смисао када се корелишу, контрола добија вредност када постоји свеж доказ да ради, а инцидент постаје прилика да се систем побољша без прикривања грешака.

ЗАШТО

Зашто је тема важна

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

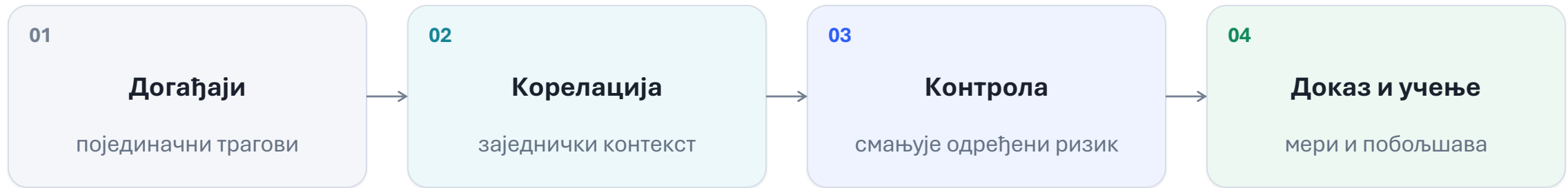
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

Догађаји

појединачни трагови

01

Корелација повезује догађаје кроз време, актере и ресурсе, а не само по једној поруци лога.

Питање: који улаз покреће ову одлуку?

02

Корелација повезује низ догађаја у једну причу о понашању система.

Питање: која граница мора бити видљива?

03

Корелациони идентификатор повезује намеру, обраду и исход једне радње.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

Корелација

заједнички контекст

01

Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Питање: који улаз покреће ову одлуку?

02

Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.

Питање: која граница мора бити видљива?

03

Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

Контрола

смањује одређени ризик

01

Пост-инцидент преглед испитује систем и процес, не тражи најближег кривца.

Питање: који улаз покреће ову одлуку?

02

Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и audit траг.

Питање: која граница мора бити видљива?

03

Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

Доказ и учење

мери и побољшава

01

Корелациони идентификатор повезује намеру, обраду и исход једне радње.

Питање: који улаз покреће ову одлуку?

02

Правила корелације морају бити објашњива, посебно када утичу на приоритет упозорења.

Питање: која граница мора бити видљива?

03

Аутоматизација предлаже или ограничава одговор када је последица грешке велика.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

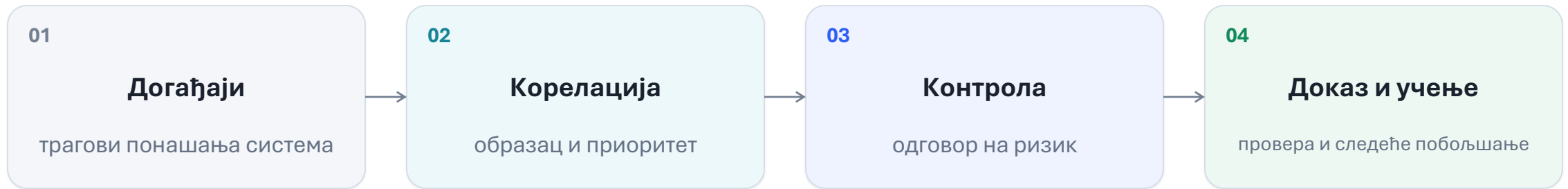
Доказ, покривеност и ефективност

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Питање	Слаб одговор	Поуздан одговор
Да ли контрола постоји?	Класа или подешавање је присутно.	Контрола има власника, активну конфигурацију и сврху.
Да ли ради?	Једном је ручно проверена.	Постоји поновљив тест или актуелан оперативни доказ.
Шта покрива?	Претпоставља се да важи свуда.	Познати су сценарио, граница и изузеци.
Како знамо да је ослабила?	Проблем се види тек после инцидента.	Метрика, alert или редован преглед откривају одступање.

Шема континуираног унапређивања безбедности

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Безбедносна повратна спрега

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

01

Догађај или тест открива образац који захтева пажњу.

02

Корелација повезује образац са имовином, актером и контролом.

03

Тим проверава да ли постојећа контрола покрива стварни сценарио.

04

Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

Контрола има смисао тек уз доказ

Три правила која треба да остану видљива у имплементацији и ревизији.

01

Корелација повезује догађаје кроз време, актере и ресурсе, а не само по једној поруци лога.

Јасно правило

02

Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Проверљива примена

03

Пост-инцидент преглед испитује систем и процес, не тражи најближег кривца.

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: контрола постоји, али нема свеж доказ

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

01

Корелација повезује низ догађаја у једну причу о понашању система.

02

Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.

03

Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и audit траг.

Корелација гради причу, не закључак из једног записа

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Finding Correlate(IEnumerable<Event> events)
2 {
3     var story = events
4         .Where(e => e.CorrelationId != null)
5         .GroupBy(e => e.CorrelationId)
6         .Select(group => timeline.Build(group));
7     return detector.FindRiskPattern(story)
8         ?? Finding.None("insufficient_context");
9 }
```

ШТА ЈЕ ВАЖНО

Време, актер, ресурс и correlation ID повезују догађаје у образац који може да се објасни.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Стар доказ не сме да изгледа као актуелна сигурност

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Control_without_fresh_evidence_is_not_effective()
3 {
4     var control = Control.Tested(monthsAgo: 8);
5
6     var score = effectiveness.Evaluate(control, changedFlow: true);
7
8     score.Status.Should().Be("unknown");
9     score.Reason.Should().Be("stale_evidence");
10 }
```

ДОКАЗ

Промена тока или истек рока враћа оцелу на непознато док се контрола поново не провери.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "control": "object-authorization",  
3   "risk": "cross-tenant-access",  
4   "lastEvidence": "2026-09-20",  
5   "coveredScenario": "foreign-record-denied",  
6   "status": "effective",  
7   "nextReview": "2026-10-20"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

**Закључивање из једног
догађаја без ширег контекста.**

Нема јасног власника одлуке.

02

**Аутоматска акција са великом
последicom без заштитне
провере.**

Не постоји негативан сценарио.

03

**Оцена контроле само по томе
да ли је имплементирана.**

Доказ не показује стварни исход.

Ефективност је више од постојања контроле

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Ефективност је више од постојања контроле

Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

01

Доказ се освежава када се промени релевантан ток, улога или граница поверења.

02

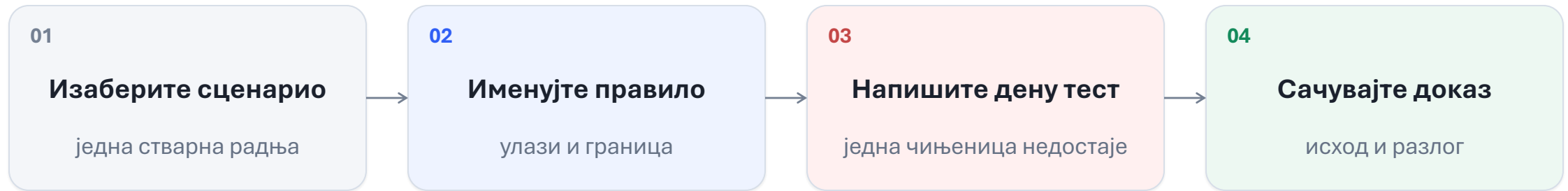
Мера ефективности не скрива непознато, већ показује где доказа нема довољно.

03

Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

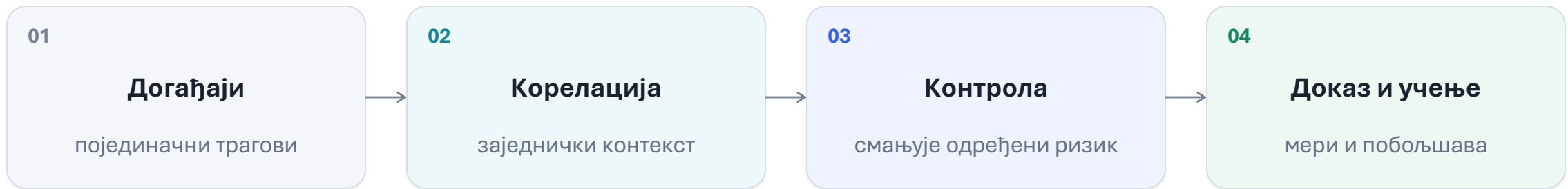


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Корелација догађаја, ефективност контрола и учење“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-a.



ЗА ЗАВРШЕТАК

Изаберите једну контролу и покажите који ризик ублажава, који доказ чува и како бисте приметили да је престала да ради.

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.